

SA-BACKEND-01 · Apartado 5

Respuesta y evidencias · Requerimiento de verificación técnica de cumplimiento previo al envío a Google Play Console

Seven Arena SPA · Área Backend / Infraestructura · Fecha de respuesta: 30 de agosto de 2026 · Responde a: SA-BACKEND-01 v1.0 (29-08-2026)

REQ.	MATERIA	ESTADO
1	Exposición pública de los buckets de almacenamiento	RESUELTO
2	Vigencia efectiva del proceso de purga	RESUELTO
3	Cifrado en tránsito e inventario de terceros	RESPONDIDO

Requisito 1 · Buckets de almacenamiento

Resultado de la verificación (1.3)

La consulta a `storage.buckets` ejecutada el 30-08-2026 arrojó seis buckets, todos con `public = true`: `athlete-photos`, `driver-documents`, `driver-photos`, `event-documents`, `provider-documents` y `venue-photos`.

El bucket `athlete-health-docs` **no existía**. Se resuelve así la disyuntiva planteada en 1.2.3 en el sentido del escenario 1.5.2: las direcciones públicas persistidas en metadata no eran operativas y la funcionalidad de carga de documentos médicos se encontraba inoperativa en el entorno productivo. **No hubo exposición efectiva de documentación médica**: el bucket nunca contuvo archivos en este entorno.

Medidas adoptadas

- **Creación del bucket con acceso privado**, versionada en el repositorio (`scripts/20260830_athlete_health_docs_private_bucket.sql`), lo que subsana además la observación 1.2.2 sobre su ausencia en las migraciones. La sentencia fuerza `public = false` aun si el bucket hubiese existido.
- **Eliminación de `getPublicUrl()`** para este bucket: la carga persiste la ruta del archivo (`medicalDocumentPath`), no una URL pública.
- **Servicio mediante URLs firmadas de vigencia limitada** (10 minutos): nuevo endpoint `GET /athletes/:id/health-document-url`, accesible únicamente por el titular del documento (sesión de portal validada) o por el personal del panel de administración (sesión Supabase, con exclusión de cuentas vinculadas a conductores). Se mantiene compatibilidad con registros antiguos derivando la ruta desde la URL pública persistida.

Evidencia

```
select id, public from storage.buckets where id = 'athlete-health-docs';
```

id	public
athlete-health-docs	false

Se acompaña captura del listado íntegro de `storage.buckets` (consulta 1.3) y de la verificación posterior a la migración.

Sobre los restantes buckets públicos: `athlete-photos`, `driver-photos`, `venue-photos` y `event-documents` contienen material operacional del evento (fotografías de perfil y de recintos, documentos de difusión) cuya publicidad es de diseño y no comprende categorías sensibles. `driver-documents` y `provider-documents` no contienen la categoría de datos de salud objeto del presente requisito; son susceptibles de migrarse al mismo esquema de URLs firmadas ya implementado, lo que se propone abordar como mejora en una próxima iteración.

Requisito 2 · Vigencia del proceso de purga

Resultado de la verificación (2.3)

```
select jobid, jobname, schedule, active from cron.job;
```

jobid	jobname	schedule	active
1	telemetry-purge-daily	0 7 * * *	true

Los tres valores coinciden con el criterio de aceptación 2.5. Adicionalmente, el historial de ejecución acredita que el proceso no sólo está programado sino que **corre a diario y concluye con éxito**:

```
select j.jobname, d.status, d.start_time from cron.job_run_details d
join cron.job j on j.jobid = d.jobid order by d.start_time desc limit 5;
```

telemetry-purge-daily	succeeded	2026-08-29 07:00:00+00
telemetry-purge-daily	succeeded	2026-08-28 07:00:00+00
telemetry-purge-daily	succeeded	2026-08-27 07:00:00+00

Se verificó asimismo que no subsisten registros con antigüedad mayor a 90 días en `telemetry.vehicle_positions` ni `telemetry.user_positions` (conteo = 0 tras el drenaje inicial del histórico).

Requisito 3 · Cifrado en tránsito e inventario de terceros

Apartado A · Cifrado en tránsito

La totalidad de la superficie pública opera exclusivamente sobre HTTPS. Ningún dato se sirve sobre tráfico no cifrado: las peticiones HTTP en el puerto 80 reciben únicamente una redirección permanente a HTTPS, verificada el 30-08-2026:

- **API backend (Railway):** `http://proyect-seven-production.up.railway.app` → 301 Moved Permanently → `https://`. TLS terminado en el proxy de la plataforma; el servicio no expone puerto sin cifrar.
- **Frontend / portales (Vercel):** `http://sevenarena.app` → 308 Permanent Redirect → `https://`.
- **Base de datos, autenticación, Storage y Realtime (Supabase):** endpoints exclusivamente TLS (`https://*.supabase.co` y WebSocket `wss://`).

Apartado B · Inventario de terceros con acceso a datos

Revisado el inventario propuesto contra el código fuente, se valida con las siguientes **precisiones e incorporaciones**:

PROVEEDOR	ENDPOINT	FINALIDAD	OBSERVACIÓN
Supabase	<code>*.supabase.co</code>	Base de datos, autenticación, Storage, Realtime	Validado
Railway	—	Alojamiento del backend	Validado
Vercel	—	Alojamiento del frontend y portales	Se incorpora
Expo Application Services	<code>exp.host</code>	Compilación y entrega de notificaciones push	Validado
Firebase Cloud Messaging	—	Transporte de notificaciones en Android	Validado
Apple Push Notification service	—	Transporte de notificaciones en iOS	Validado
AeroDataBox	<code>api.magicapi.dev</code>	Datos de estado de vuelos	Precisión: se consume a través del marketplace MagicAPI
AviationStack	<code>api.aviationstack.com</code>	Fuente alternativa de datos de vuelos, conmutable por configuración	Se incorpora
OpenAI	<code>api.openai.com</code>	Asistente SoflA · modelo <code>gpt-4o-mini</code> (verificado en código)	Validado

Resend	<code>api.resend.com</code>	Correo transaccional: envío de códigos de acceso y control de acceso	Se incorpora — categoría "correo transaccional" consultada
Google Maps Platform	<code>maps.googleapis.com</code>	Mapas, geocodificación, rutas y ETA en los portales; recibe coordenadas y direcciones desde el cliente	Se incorpora — relevante para la sección de ubicación del formulario
Boostr	<code>api.boostr.cl</code>	Consulta de datos vehiculares por patente	Se incorpora

Los portales ofrecen además enlaces de navegación hacia Waze y Google Maps (se abre la aplicación elegida por el conductor con la dirección de destino); no constituyen integración de datos del backend.

Servicios adicionales (monitoreo, analítica, mesa de ayuda u otros): no se emplean servicios de terceros adicionales a los consignados. El soporte a usuarios y el asistente operativo son componentes propios de la plataforma.

Anexo · Evidencias adjuntas

1. Captura: listado íntegro de `storage.buckets` (consulta 1.3).
2. Captura: `athlete-health-docs · public = false` tras la migración.
3. Captura: fila de `cron.job` (consulta 2.3).
4. Captura: historial `cron.job_run_details` con ejecuciones `succeeded`.
5. Captura: `curl -i http://...` con redirecciones 301 (Railway) y 308 (Vercel).